

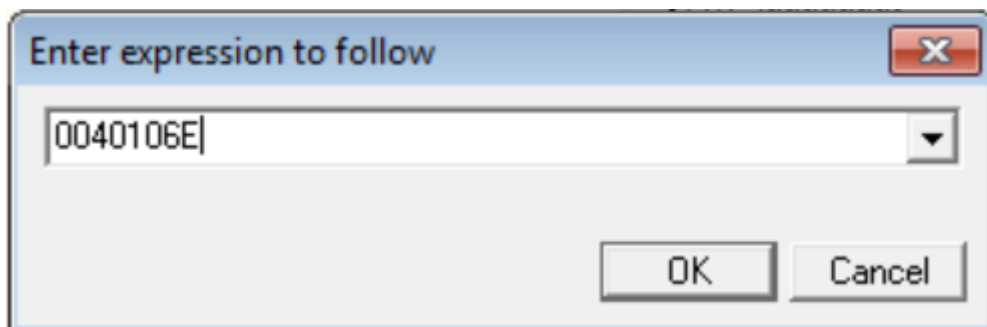
OllyDBG

Traccia:

Fate riferimento al malware: Malware_U3_W3_L3, presente all'interno della cartella Esercizio_Pratico_U3_W3_L3 sul desktop della macchina virtuale dedicata all'analisi dei malware. Rispondete ai seguenti quesiti utilizzando OllyDBG.

- All'indirizzo 0040106E il Malware effettua una chiamata di funzione alla funzione «CreateProcess». Qual è il valore del parametro «CommandLine» che viene passato sullo stack? (1)
- Inserite un breakpoint software all'indirizzo 004015A3. Qual è il valore del registro EDX? (2) Eseguite a questo punto uno «step-into». Indicate qual è ora il valore del registro EDX (3) motivando la risposta (4). Che istruzione è stata eseguita? (5)
- Inserite un secondo breakpoint all'indirizzo di memoria 004015AF. Qual è il valore del registro ECX? (6) Eseguite uno step-into. Qual è ora il valore di ECX? (7) Spiegate quale istruzione è stata eseguita (8).
- BONUS: spiegare a grandi linee il funzionamento del malware

1) Per prima cosa bisogna trovare l'indirizzo 0040106E. Il modo più veloce è premere Ctrl + G per aprire una finestra di ricerca e inserire l'indirizzo desiderato



Così facendo ci troveremo in questa schermata

Address	Hex dump	ASCII
00405000	00 00 00 00 00 00 00 00	
00405008	00 00 00 00 F8 27 40 00	070.
00405010	00 00 00 00 00 00 00 00	
00405018	00 00 00 00 00 00 00 00	
00405020	00 00 00 00 00 00 00 00	
00405028	00 00 00 00 00 00 00 00	
00405030	63 6D 64 00 46 06 16 54	cmd.Fa.T
00405038	42 05 12 1B 47 00 07 02	24+G.-0
00405040	50 1C 00 16 45 16 01 10	l...E.0
00405048	52 00 05 0F 48 02 08 09	R24#H00.
00405050	1C 14 1C 15 00 00 00 00	L4LS....
00405058	00 00 00 00 00 00 00 00	
00405060	00 16 40 00 01 00 00 00	..0.0...

A questo punto, usando il tasto F2, metteremo un breakpoint

0040105F	6A 00	PUSH 0
00401061	6A 01	PUSH 1
00401063	6A 00	PUSH 0
00401065	6A 00	PUSH 0
00401067	68 30504000	PUSH Malware_.00405030
00401069	6A 00	PUSH 0
0040106E	FF15 04404000	CALL DWORD PTR DS:[&KERNEL32.CreateProcessA]
00401074	8945 EC	MOV DWORD PTR SS:[EBP-14],EAX
00401077	6A FF	PUSH -1
00401079	8B4D F0	MOV ECX,DWORD PTR SS:[EBP-10]
0040107C	51	PUSH ECX
0040107D	FF15 00404000	CALL DWORD PTR DS:[&KERNEL32.WaitForSingleObject]
00401083	33C0	XOR EAX,EAX

Infine ho fatto partire il malware così che si fermasse al breakpoint e da lì ho iniziato a controllare e vedendo l'informazione sui processi possiamo vedere che il valore del parametro "CommandLine" è cmd

```

pProcessInfo
pStartupInfo
CurrentDir = NULL
pEnvironment = NULL
CreationFlags = 0
InheritHandles = TRUE
pThreadSecurity = NULL
pProcessSecurity = NULL
CommandLine = "cmd"
ModuleFileName = NULL
CreateProcessA

```

2) Adesso andiamo a inserire un breakpoint all' indirizzo 004015A3 come abbiamo fatto in precedenza

0040159A	8965 E8	MOV DWORD PTR SS:[EBP-18],ESP
0040159D	FF15 30404000	CALL DWORD PTR DS:[<&KERNEL32.GetVersion>]
004015A3	33D2	XOR EDX,EDX
004015A5	8AD4	MOV DL,AH
004015A7	8915 D4524000	MOV DWORD PTR DS:[4052D4],EDX
004015AD	8BC8	MOV ECX,EAX
004015AF	81E1 FF000000	AND ECX,0FF

Usando F8 (Step Over) per andare avanti con il malware finchè non arriviamo al nostro breakpoint e, usando la schermata alla nostra destra, possiamo vedere il valore del registro EDX, che in questo caso è 00001DB1

00401561	4F	DEC EDI			Registers (MMX)
00401562	8A45 0C	MOV AL,BYTE PTR SS:[EBP+C]			EAX 10B10106
00401565	FD	STD			ECX 7EFDE000
00401566	F2AE	REPNE SCAS BYTE PTR ES:[EDI]			EDX 00001DB1
00401569	47	INC EDI			EBX 7EFDE000
00401569	3807	CMF BYTE PTR DS:[EDI],AL			ESP 0018FF5C
0040156B	74 04	JE SHORT Malware_.00401571			EBP 0018FF88
0040156D	33C0	XOR EAX,EAX			ESI 00000000
0040156F	EB 02	JMP SHORT Malware_.00401573			EDI 00000000
00401571	8BC7	MOV EAX,EDI			EIP 004015A3 Malware_.004015A3
00401573	FC	CLD			C 0 ES 002B 32bit 0(FFFFFFFF)
00401574	5F	POP EDI			P 1 CS 0023 32bit 0(FFFFFFFF)
00401575	C9	LEAVE			A 0 SS 002B 32bit 0(FFFFFFFF)
00401576	C3	RETN			Z 0 DS 002B 32bit 0(FFFFFFFF)
00401577	55	PUSH EBP			S 0 FS 0053 32bit 7EFD0000(FFF)
00401578	8BEC	MOV EBP,ESP			T 0 GS 002B 32bit 0(FFFFFFFF)
0040157A	6A FF	PUSH -1			D 0
0040157C	68 C0404000	PUSH Malware_.004040C0			O 0 LastErr ERROR_SUCCESS (00000000)
00401581	68 3C204000	PUSH Malware_.0040203C	SE handler installation		EFL 00000206 (NO,NB,NE,A,NS,PE,GE,G)
00401586	64A1 00000000	MOV EAX,DWORD PTR FS:[0]			MM0 0000 0000 0000 0000
0040158C	50	PUSH EAX			MM1 0000 0000 0000 0000
0040158D	648925 000000	MOV DWORD PTR FS:[0],ESP			MM2 0000 0000 0000 0000
00401594	83EC 10	SUB ESP,10			MM3 0000 0000 0000 0000
00401597	53	PUSH EBX			MM4 0000 0000 0000 0000
00401598	56	PUSH ESI			MM5 0000 0000 0000 0000
00401599	57	PUSH EDI			MM6 0000 0000 0000 0000
00401599	8965 E8	MOV DWORD PTR SS:[EBP-18],ESP	kernel32.GetVersion		MM7 0000 0000 0000 0000
0040159D	FF15 30404000	CALL DWORD PTR DS:[<&KERNEL32.GetVersion>]			
004015A3	33D2	XOR EDX,EDX			
004015A5	8AD4	MOV DL,AH			

3-4-5) A questo punto eseguiamo uno "step-into". Così facendo ci spostiamo qui

0040159D	FF15 30404000	CALL DWORD PTR DS:[<&KERNEL32.GetVersion>]
004015A3	33D2	XOR EDX,EDX
004015A5	8AD4	MOV DL,AH
004015A7	8915 D4524000	MOV DWORD PTR DS:[4052D4],EDX
004015AD	8BC8	MOV ECX,EAX

Registers (FPU)			
EAX	10B10106		
ECX	7EFDE000		
EDX	00000000		
EBX	7EFDE000		
ESP	0018FF5C		
EBP	0018FF88		
ESI	00000000		
EDI	00000000		

Dove il valore del registro EDX è 00000000

Quando si utilizza il comando Step Into su un'istruzione come XOR, se questa non contiene chiamate a funzioni o salti condizionali, il debugger eseguirà semplicemente quella singola istruzione e passerà alla successiva, come in questo caso.

6)Andiamo ad inserire un altro breakpoint

004015A5	8AD4	MOV DL,AH
004015A7	8915 D4524000	MOV DWORD PTR DS:[4052D4],EDX
004015AD	8BC8	MOV ECX,EAX
004015AF	81E1 FF000000	AND ECX,0FF
004015B5	890D D4524000	MOV DWORD PTR DS:[4052D0],ECX
004015BB	C1E1 08	SHL ECX,8
004015BE	03CA	ADD ECX,EDX

Dove vediamo che il valore di EDX è 00000001

Registers (FPU)	
EAX	10B10106
ECX	10B10106
EDX	00000001
EBX	7EFDE000
ESP	0018FF5C
EBP	0018FF88
ESI	00000000
EDI	00000000
EIP	004015AF Malware_.004015AF
C 0	ES 002B 32bit 0(FFFFFFFF)
P 1	CS 0023 32bit 0(FFFFFFFF)
A 0	SS 002B 32bit 0(FFFFFFFF)
Z 1	DS 002B 32bit 0(FFFFFFFF)
S 0	FS 0053 32bit 7EFDD000(FFF)
T 0	GS 002B 32bit 0(FFFFFFFF)
D 0	
O 0	LastErr ERROR_SUCCESS (00000000)
EFL	00000246 (NO,NB,E,BE,NS,PE,GE,LE)

Eseguiamo lo step-into. Così ci spostiamo 004015B5.

004015AD	. 8BC8	MOV ECX,EAX
004015B0	. 81F1 55000000	AND ECX,0FF
004015B5	. 890D 00524000	MOV DWORD PTR DS:[4052D0],ECX
004015BB	. C1E1 08	SAL ECX,8
004015BE	. 03CA	ADD ECX,EDX

Registers (FPU)	
EAX	10B10106
ECX	00000006
EDX	00000001
EBX	7EFDE000
ESP	0018FF5C
EBP	0018FF88
ESI	00000000
EDI	00000000

Ora il valore di ECX è

Quando esegui Step Into sull'istruzione AND esegue l'istruzione e si posiziona sulla successiva, ovvero MOV DWORD PTR DS: [4052D0], ECX.